

Security+ 1.4 · Key Exchange

Mestre CyberSec — PDF baseado na aula do Professor Messer · 1.4 — Key Exchange (3:39) · [vídeo original](#)
[↗](#) · [YouTube](#) [↗](#)

Diffie-Hellman: duas partes derivam a MESMA chave secreta trocando só valores PÚBLICOS — sem enviar a chave! Na TLS moderna usa-se ECDHE (efêmero): chave NOVA a cada sessão, dando Perfect Forward Secrecy (se a chave privada vazar amanhã, sessões passadas não decifram).

💡 Highlights que a prova cobra

- DH troca valores públicos e deriva chave privada — a chave NUNCA viaja
- Ephemeral (ECDHE) = chave por sessão — PFS
- PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas

🎯 Dicas de prova

- 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman
- 'protects past sessions even if key leaks' = Perfect Forward Secrecy

Cenário clássico: Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' → Diffie-Hellman.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Trocar uma chave secreta por canal público SEM enviá-la diretamente usa:
A) Diffie-Hellman
B) AES
C) SHA-256
D) Base64

2. Qual tipo de criptografia usa pares de chaves pública e privada?

- A)** Hashing
- B)** Criptografia simétrica
- C)** Criptografia assimétrica
- D)** Steganografia

3. AES é um exemplo de criptografia:

- A)** Simétrica (mesma chave cifra e decifra)
- B)** Assimétrica (par de chaves)
- C)** Hash de mão única
- D)** Codificação Base64

4. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'DH troca valores públicos e deriva chave privada — a chave NUNCA viaja'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DH troca valores públicos e deriva chave privada — a chave NUNCA viaja...

5. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Ephemeral (ECDHE) = chave por sessão — PFS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Ephemeral (ECDHE) = chave por sessão — PFS...

6. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas...

7. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: "requires parties to derive a shared secret over untrusted channel" = Diffie-Hellman'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'requires parties to derive a shared secret over untrusted channel' = Diffi...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: "protects past sessions even if key leaks" = Perfect Forward Secrecy'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'protects past sessions even if key leaks' = Perfect Forward Secrecy...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' → Diffie-Hellman.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' →...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'DH troca valores públicos e deriva chave privada — a chave NUNCA viaja'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: DH troca valores públicos e deriva chave privada — a chave NUNCA viaja...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Diffie-Hellman.** Diffie-Hellman deixa duas partes derivarem a MESMA chave secreta trocando só valores públicos. Base da troca de chave do TLS.
- 2) C — Criptografia assimétrica.** Criptografia assimétrica (como RSA, ECC) usa par de chaves matematicamente relacionadas: pública para criptografar e privada para descriptografar, ou vice-versa para assinatura.
- 3) A — Simétrica (mesma chave cifra e decifra).** AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação.
- 4) D — Implementar a solução correspondente: DH troca valores públicos e deriva chave p.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): DH troca valores públicos e deriva chave privada — a chave NUNCA viaja. As demais alternativas configuram violações grav
- 5) D — Implementar a solução correspondente: Ephemeral (ECDHE) = chave por sessão — PFS.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): Ephemeral (ECDHE) = chave por sessão — PFS. As demais alternativas configuram violações graves de conformidade ou falhas
- 6) D — Implementar a solução correspondente: PFS = se a chave privada vazar, as sessões.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas. As demais alternativas configuram violações grav
- 7) A — Implementar a solução correspondente: 'requires parties to derive a shared secre.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman. As demais alternativas configuram
- 8) C — Implementar a solução correspondente: 'protects past sessions even if key leaks'.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): 'protects past sessions even if key leaks' = Perfect Forward Secrecy. As demais alternativas configuram violações graves
- 9) C — Implementar a solução correspondente: Cenário típico: 'dois sistemas estabelecem.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' → Diffie-Hellman.. As demais alternativas conf
- 10) C — Implementar a solução correspondente: DH troca valores públicos e deriva chave p.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): DH troca valores públicos e deriva chave privada — a chave NUNCA viaja. As demais alternativas configuram violações grav

